

Panduan Integrasi SSO Clara

Dashboard Live Chat

FLOW	OAuth 2.0 Authorization Code + PKCE S256
ISSUER	https://crm.sg-berjangka.com/api
STATUS	Implemented - menunggu konfigurasi dan E2E

Dokumen teknis untuk Tim Clara dan Tim Live Chat

Versi 1.0 | 03 September 2026

1. Tujuan

Dokumen ini menjadi panduan teknis bagi Tim Clara dan Tim Live Chat untuk mengaktifkan login Dashboard Live Chat menggunakan akun Clara.

SSO ini terpisah dari API sinkronisasi conversation. API conversation memakai service credential milik Clara Backend, sedangkan SSO memverifikasi identitas agent yang membuka Dashboard Live Chat.

2. Endpoint

Method	Endpoint	Fungsi
GET	<code>/.well-known/openid-configuration</code>	Membaca metadata endpoint dan kemampuan SSO
GET	<code>/oauth/authorize</code>	Memulai login dan menerbitkan authorization code
POST	<code>/oauth/token</code>	Menukar authorization code dengan token
GET	<code>/oauth/userinfo</code>	Mengambil identitas user aktif dari access token
POST	<code>/oauth/introspect</code>	Memeriksa status dan claims access token

Semua URL production wajib menggunakan HTTPS.

3. Tanggung Jawab Setiap Tim

Tim Clara

- Menyediakan base URL SSO yang dapat diakses Backend Live Chat.
- Mendaftarkan `client_id`, client secret, dan redirect URI Live Chat.
- Menjaga authorization code tetap sekali pakai dan berumur pendek.
- Menerbitkan identitas user berdasarkan akun Clara yang masih aktif.
- Menolak user tanpa organization atau role yang tidak diizinkan.

Tim Live Chat

- Membuat `state`, `nonce`, dan pasangan PKCE baru untuk setiap login.
- Menyimpan `state`, `nonce`, dan `code_verifier` sementara di session server.
- Memvalidasi `state` sebelum menukar authorization code.
- Menukar code hanya dari backend, bukan JavaScript browser.
- Memvalidasi ID token sebelum membuat session Dashboard Live Chat.
- Menyimpan claim `sub` sebagai `claraUserId` yang stabil.
- Mengisolasi data berdasarkan `organizationId`.

4. Konfigurasi Clara

Tambahkan konfigurasi berikut pada environment Clara Backend:

```
SSO_ISSUER=https://crm.sg-berjangka.com/api
SSO_LOGIN_URL=https://crm.sg-berjangka.com/login
SSO_CLIENT_ID=live-chat-dashboard
SSO_CLIENT_SECRET=<RANDOM_SECRET_MINIMUM_32_CHARACTERS>
SSO_REDIRECT_URI=https://live-chat.example.com/auth/clara/callback
SSO_SIGNING_SECRET=<DIFFERENT_RANDOM_SECRET_MINIMUM_32_CHARACTERS>
SSO_CODE_EXPIRE_SECONDS=120
SSO_ACCESS_TOKEN_EXPIRE_MINUTES=5
SSO_ALLOWED_ROLES=sales,manager,head,superadmin
SSO_RATE_LIMIT_PER_MINUTE=60
```

Jika ada lebih dari satu redirect URI, pisahkan dengan koma. Pencocokan redirect URI dilakukan secara exact match.

Gunakan tiga secret yang berbeda untuk `JWT_SECRET_KEY`, `SSO_CLIENT_SECRET`, dan `SSO_SIGNING_SECRET`. `SSO_CLIENT_SECRET` dibagikan hanya ke Backend Live Chat, sedangkan `SSO_SIGNING_SECRET` tetap menjadi secret internal Clara.

Dashboard Clara juga membutuhkan:

```
NEXT_PUBLIC_SSO_ISSUER=https://crm.sg-berjangka.com/api
```

Setelah konfigurasi database tersedia, jalankan migrasi:

```
cd clara-backend
uv run alembic upgrade head
```

5. Alur Login

```
Browser agent
|
| 1. Buka /oauth/authorize dengan state, nonce, dan PKCE challenge

Clara Backend
|
| └─ Belum login -> redirect ke halaman login Clara
|      lalu kembali ke /oauth/authorize
|
| 2. User dan request divalidasi
| 3. Authorization code sekali pakai dibuat

Callback Live Chat
|
| 4. Validasi state
| 5. Backend menukar code + code_verifier di /oauth/token
| 6. Validasi ID token dan nonce

Session Dashboard Live Chat dibuat
```

6. Membuat PKCE, State, dan Nonce

Contoh Node.js di Backend Live Chat:

```
import crypto from "node:crypto"

const base64url = (value) =>
  value.toString("base64").replaceAll("+", "-").replaceAll("/", "_").replace(/=+$/, "")

const state = base64url(crypto.randomBytes(32))
const nonce = base64url(crypto.randomBytes(32))
const codeVerifier = base64url(crypto.randomBytes(64))
const codeChallenge = base64url(
  crypto.createHash("sha256").update(codeVerifier, "ascii").digest()
)
```

`code_verifier` harus berisi 43-128 karakter yang valid menurut PKCE. Jangan menggunakan nilai statis atau memakai ulang nilai dari login sebelumnya.

7. Authorization Endpoint

Contoh redirect browser menuju Clara:

```
GET https://crm.sg-berjangka.com/api/oauth/authorize
?client_id=live-chat-dashboard
&redirect_uri=https%3A%2F%2Flive-chat.example.com%2Fauth%2Fclara%2Fcallback
&response_type=code
&scope=openid%20profile%20email
&state=<RANDOM_STATE>
&nonce=<RANDOM_NONCE>
&code_challenge=<PKCE_CHALLENGE>
&code_challenge_method=S256
```

Parameter yang wajib:

Parameter	Aturan
<code>client_id</code>	Harus sama dengan client yang didaftarkan
<code>redirect_uri</code>	Harus exact match dengan allowlist Clara
<code>response_type</code>	Harus <code>code</code>
<code>scope</code>	Harus tepat berisi <code>openid profile email</code>
<code>state</code>	Acak, 16-512 karakter, dan diverifikasi Live Chat
<code>nonce</code>	Acak, 16-255 karakter, dan diverifikasi terhadap ID token
<code>code_challenge</code>	PKCE challenge sepanjang 43-128 karakter
<code>code_challenge_method</code>	Harus <code>S256</code>

Jika agent belum memiliki session Clara, Clara mengarahkannya ke halaman login. Setelah login berhasil, agent kembali ke authorization endpoint yang sama.

Response sukses adalah redirect `302` menuju callback terdaftar:

```
HTTP/1.1 302 Found
Location:
https://live-chat.example.com/auth/clara/callback?code=<ONE_TIME_CODE>&state=<ORIGINAL_STATE>
Cache-Control: no-store
Pragma: no-cache
```

Authorization code berlaku 120 detik secara default, disimpan sebagai hash di database, terikat pada client, redirect URI, dan PKCE, serta hanya bisa dipakai sekali.

8. Token Endpoint

Setelah memastikan `state` sama dengan nilai dalam session, Backend Live Chat menukar code. HTTP Basic adalah cara autentikasi client yang direkomendasikan:

```
curl --request POST \
--url 'https://crm.sg-berjangka.com/api/oauth/token' \
--user 'live-chat-dashboard:<LIVE_CHAT_OAUTH_CLIENT_SECRET>' \
--header 'Content-Type: application/x-www-form-urlencoded' \
--data-urlencode 'grant_type=authorization_code' \
--data-urlencode 'code=<ONE_TIME_CODE>' \
--data-urlencode 'redirect_uri=https://live-chat.example.com/auth/clara/callback' \
--data-urlencode 'code_verifier=<ORIGINAL_PKCE_VERIFIER>'
```

`client_id` dan `client_secret` juga didukung melalui form body untuk kompatibilitas. Jangan pernah mengirim client secret melalui query parameter atau frontend.

Response sukses:

```
{
  "access_token": "<ACCESS_TOKEN>",
  "token_type": "Bearer",
  "expires_in": 300,
  "scope": "openid profile email",
  "id_token": "<ID_TOKEN>"
}
```

Token response dikirim dengan **Cache-Control**: no-store dan **Pragma**: no-cache.

9. Validasi ID Token

ID token adalah JWT **HS256** yang ditandatangani menggunakan **SSO_CLIENT_SECRET**. Backend Live Chat wajib memvalidasi:

- Algoritma hanya **HS256**; jangan menerima algoritma dari token secara bebas.
- Signature menggunakan client secret Live Chat.
- **iss** sama persis dengan **SSO_ISSUER**.
- **aud** sama dengan **live-chat-dashboard**.
- **exp** belum lewat.
- **nonce** sama dengan nilai yang disimpan untuk login tersebut.
- **sub** tersedia dan digunakan sebagai **claraUserId**.
- **isActive** bernilai **true**.
- **organizationId** tidak kosong.
- **role** termasuk role yang disepakati.

Contoh claims ID token:

```
{
  "iss": "https://crm.sg-berjangka.com/api",
  "aud": "live-chat-dashboard",
  "sub": "8a1d0f7c-1d45-4c0a-9058-2d2b58544e70",
  "name": "Andi",
  "email": "andi@company.com",
  "role": "sales",
  "organizationId": "77bd68a7-fd22-4db8-a1b7-9505d18531b4",
  "teamId": "7e79fc33-708f-489d-b678-4eebf0cbecc9",
  "isActive": true,
  "scope": "openid profile email",
  "token_use": "id",
  "nonce": "<ORIGINAL_NONCE>",
  "iat": 1788400000,
  "exp": 1788400300,
  "jti": "<TOKEN_ID>"
}
```

Nama dan email hanya data tampilan. Jangan menjadikannya primary key atau dasar ownership conversation.

10. UserInfo Endpoint

Endpoint ini menerima access token dan mengembalikan kondisi user terbaru:

```
curl --request GET \
  --url 'https://crm.sg-berjangka.com/api/oauth/userinfo' \
  --header 'Authorization: Bearer <ACCESS_TOKEN>'
```

Response sukses:

```
{
  "sub": "8a1d0f7c-1d45-4c0a-9058-2d2b58544e70",
  "name": "Andi",
  "email": "andi@company.com",
  "role": "sales",
  "organizationId": "77bd68a7-fd22-4db8-a1b7-9505d18531b4",
  "teamId": "7e79fc33-708f-489d-b678-4eebf0cbecc9",
  "isActive": true
}
```

11. Introspection Endpoint

Introspection direkomendasikan ketika Live Chat ingin memastikan access token dan user masih aktif tanpa menerima **SSO_SIGNING_SECRET** internal Clara:

```
curl --request POST \
  --url 'https://crm.sg-berjangka.com/api/oauth/introspect' \
  --user 'live-chat-dashboard:<LIVE_CHAT_OAUTH_CLIENT_SECRET>' \
  --header 'Content-Type: application/x-www-form-urlencoded' \
  --data-urlencode 'token=<ACCESS_TOKEN>'
```

Response token aktif:

```
{
  "active": true,
  "sub": "8a1d0f7c-1d45-4c0a-9058-2d2b58544e70",
  "client_id": "live-chat-dashboard",
  "scope": "openid profile email",
  "exp": 1788400300,
  "iat": 1788400000,
  "name": "Andi",
  "email": "andi@company.com",
  "role": "sales",
  "organizationId": "77bd68a7-fd22-4db8-a1b7-9505d18531b4",
  "teamId": null,
  "isActive": true
}
```

Token tidak valid, kedaluwarsa, atau milik user nonaktif menghasilkan:

```
{
  "active": false
}
```

12. Discovery Endpoint

Metadata endpoint dapat dibaca dari:

```
GET https://crm.sg-berjangka.com/api/.well-known/openid-configuration
```

Implementasi saat ini menggunakan satu confidential client, ID token **HS256**, dan introspection. Clara tidak menyediakan JWKS karena symmetric signing key tidak boleh dipublikasikan.

13. Error dan Rate Limit

Error validasi bisnis SSO menggunakan status **400** atau **401**:

```
{
  "detail": {
    "error": "invalid_request",
    "error_description": "Authorization code tidak valid atau sudah digunakan."
  }
}
```

Input HTTP yang hilang atau tidak sesuai tipe dapat menghasilkan **422** dengan format validation error FastAPI.

Endpoint token dan introspection dibatasi berdasarkan IP. Jika limit terlampaui:

HTTP/1.1 429 Too Many Requests
Retry-After: 60

```
{
  "detail": {
    "error": "slow_down"
  }
}
```

14. Checklist Pengujian Staging

- [] Migrasi database berhasil diterapkan.
- [] Base URL SSO staging dapat diakses melalui HTTPS.
- [] Client secret dibuat acak, minimal 32 karakter, dan dikirim lewat kanal aman.
- [] Redirect URI staging terdaftar dan exact match.
- [] Agent tanpa session diarahkan ke login Clara.
- [] Login berhasil kembali ke callback Live Chat.
- [] `state` dan `nonce` yang salah ditolak oleh Live Chat.
- [] PKCE verifier yang salah ditolak Clara.
- [] Authorization code kedaluwarsa ditolak.
- [] Authorization code yang digunakan ulang ditolak.
- [] Redirect URI yang tidak terdaftar ditolak.
- [] Client secret yang salah ditolak.
- [] User nonaktif, tanpa organization, atau role terlarang ditolak.
- [] `sub` disimpan sebagai `claraUserId`.
- [] Agent tidak dapat mengakses organization lain.
- [] Logout menghapus session lokal Live Chat.
- [] Token dan secret tidak muncul di URL, frontend, atau log.

15. Informasi yang Harus Dipertukarkan

Tim Clara memberikan:

Clara SSO Base URL	:	
SSO Client ID	:	live-chat-dashboard
OAuth Client Secret	:	<dikirim melalui kanal secret yang aman>
Authorization Endpoint	:	/oauth/authorize
Token Endpoint	:	/oauth/token
UserInfo Endpoint	:	/oauth/userinfo
Introspection Endpoint	:	/oauth/introspect
ID Token Algorithm	:	HS256
Allowed Roles	:	sales, manager, head, superadmin

Tim Live Chat memberikan:

Staging Redirect URI	:	
Production Redirect URI	:	
Dashboard Base URL	:	
Session TTL	:	
Technical Contact	:	

16. Batasan Implementasi Saat Ini

- Hanya satu OAuth client yang dikonfigurasi melalui environment.
- ID token menggunakan symmetric signature [HS256](#); belum ada JWKS.
- Rate limit disimpan di memory masing-masing process, sehingga pada deployment

multi-replica batas efektif berlaku per replica.

- Refresh token, dynamic client registration, consent screen, dan single logout

belum tersedia.

Tambahkan client registry, asymmetric signing ([RS256/ES256](#)) dan JWKS ketika Clara perlu melayani lebih dari satu aplikasi atau integrasi pihak ketiga.